

ABHI SHARMA

linkedin.com/in/a13h1 | abhis9102@gmail.com
hackerone.com/root_a13h1 | medium.com/@a13h1 | abhis9102.github.io/a13h1

PROFESSIONAL SUMMARY

Offensive Security Engineer specializing in Web Application Security, API Security, Application Security, and Vulnerability Research. Delivers penetration testing engagements across **10+ enterprise clients** under NDA, building on prior experience at Certree and Writing.com. Proven expertise in Broken Access Control, Business Logic flaws, Authentication and Authorization testing, and Session Management across modern SaaS platforms. Active HackerOne researcher (**4,000+** reputation, **100+** valid reports) and developer of **Hackbot**, a Claude-powered agentic pentesting framework with 25 methodology documents. Currently preparing for OSCP and building hands-on Cloud Security / DevOps skills (Kubernetes, AWS, Terraform, CI/CD).

TECHNICAL SKILLS

Offensive Security: Web App Pentesting, API Security Testing, Application Security, Vulnerability Assessment, **Secure SDLC**, Security Reporting, **OWASP** Top 10, CVSS

Web Security Tools (DAST): Burp Suite Professional, **OWASP** ZAP, SQLMap, XSSStrike

Reconnaissance: Katana, httpx, nuclei, ffuf, Amass, Subfinder, Assetfinder, LinkFinder, SecretFinder, gau, waybackurls

Network Security: Nmap, Metasploit, Wireshark

Infrastructure: Linux, Windows, Active Directory, SMB, Kerberos, DNS, TCP/IP, HTTP/HTTPS, SSH

Programming: Python, Bash, JavaScript

AI / Agentic Tooling: Claude-based agent design (ReAct loop, tool orchestration, evidence/critic pipelines), LLM-assisted vulnerability research and triage

EXPERIENCE

Independent Cybersecurity Consultant

FREELANCE

Oct 2022 – Present

- Identify and engage prospective clients, converting outreach into contracted penetration testing engagements and managing each relationship through delivery.
- Authenticated and unauthenticated penetration tests on web applications and REST APIs for **10+ enterprise clients** under NDA, owned end to end from outreach through delivery and remediation.
- 300+** confirmed vulnerabilities including **30+ Critical** and **100+ High**: SQL injection, XSS, IDOR/broken access control, SSRF, CSRF, privilege escalation and business logic flaws.
- Findings include an admin-panel takeover at D2C Media (**1,000+** dealer customers, later acquired by Cars.com for **CAD \$105M**), authorization flaws exposing protected health information on a telehealth service used by **1M+** students, and a Viewer to Administrator escalation across all products on a SaaS platform serving **20,000+ organizational clients**.
- Design reconnaissance and attack-surface mapping **workflows** across client estates, covering subdomain enumeration, HTTP probing, JavaScript analysis and endpoint discovery, to prioritise high-risk functionality before manual testing.
- Specialise in authorization testing: enumerate every role, then replay state-changing requests across identities to surface IDOR/BOLA, privilege escalation and tenant-boundary failures that automated scanning does not reach.
- Sectors covered** include healthcare, HR-tech and payroll, scheduling, observability and monitoring, CDN/edge infrastructure, scientific computing, subscription billing and cloud communications (UCaaS).
- Collectively these platforms serve **3M+** end users and support **50,000+ organizational clients**, safeguarding sensitive customer, health and business data, and reducing attack surface at scale.
- Work with client engineering teams to help them write **secure code**, sharing the vulnerability patterns worth watching for during development and shifting security left rather than relying on point-in-time testing.
- Author CVSS-scored reports with remediation guidance, then work alongside client engineering through fix and re-validation cycles.

Cyber Security Consultant

CERTREE (UBERTAL INDIA PVT. LTD.)

Feb 2022 – Aug 2022

- Conducted application security assessments of Certree, a **zero-trust** document verification and storage platform handling sensitive personal and employment records.

- Identified and reported **38** confirmed vulnerabilities, spanning 13 XSS, 10 Broken Access Control, 7 IDOR, 3 SSRF via PDF rendering, 2 HTML Injection, and 3 Privilege Escalation issues that could expose sensitive document data, plus multiple additional low-severity findings (session management, session expiration).
- Collaborated with developers to validate findings and translate them into actionable remediation.
- Performed manual and automated testing using **Burp Suite Professional** and **OWASP ZAP** across authentication and session-handling flows to identify exploitable weaknesses.
- Documented findings in structured reports with severity ratings, reproduction steps, and clear remediation steps for the engineering team.
- Retested and verified fixes across remediation cycles to confirm vulnerabilities were fully resolved before sign-off.
- Produced security best-practice guidance to educate staff on common threats and attack vectors, while sustaining product security through ongoing testing.
- Earned a formal recommendation from the **CTO** for penetration testing and security consulting contributions.

Independent Cyber Security Consultant

WRITING.COM

Jun 2020 – Jan 2022

- Provided continuous security assessment coverage for a large-scale creative-writing community platform (**2M+** registered users).
- Mapped the attack surface and enumerated endpoints ahead of manual testing to prioritize high-risk functionality.
- Carried out manual testing of authentication, session management, and access-control logic across core platform **workflows**.
- Identified and reported **171** confirmed vulnerabilities to the **Founder**, spanning 57 XSS, 38 Business Logic, 33 IDOR/Broken Access Control, 13 SQL Injection, 10 CSRF, 8 file/attachment-handling issues, 7 information disclosure/LFI, 4 open redirect, and 1 high-severity SSRF finding.
- Notable finding: critical pre-authentication SQL injection via the date-of-birth parameter on the public user registration endpoint, reachable without an account, with database data extraction confirmed during validation.
- Tracked reported vulnerabilities through to resolution, retesting fixes across multiple engagement cycles to confirm remediation.
- Recognized by the **Founder** with a formal recommendation for consulting and technical contributions to the platform.

PROJECTS

Hackbot: Custom Agentic Vulnerability Research Framework: Built a Claude-powered autonomous pentesting agent (ReAct loop with a critic module that blocks unconfirmed findings before they are reported) covering 25 methodology documents across major vulnerability classes. Produced a confirmed, CVSS-scored, independently-reproduced cross-tenant BOLA finding on a production SaaS GraphQL/REST API.

Automated Reconnaissance Framework: Integrated open-source offensive security tooling for attack surface mapping, subdomain enumeration, HTTP probing, JavaScript analysis, endpoint discovery, and technology fingerprinting.

CERTIFICATIONS

Currently preparing: Offensive Security Certified Professional (OSCP)

EDUCATION

Sri Aurobindo Institute of Technology, Indore, Madhya Pradesh

Bachelor of Technology in Computer Science and Engineering, CGPA 6.55, Class of 2022

ACHIEVEMENTS

- **HackerOne:** Active Security Researcher with **4,000+** reputation and **100+** valid reports submitted and resolved.
- **Client Recommendations:** Formal recommendations from the **Founder** of Writing.com and the **CTO** of Certree.
- **Technical Writing:** Publishes near-weekly writeups on Medium.
- **Community:** Volunteer at BSides Goa.